LABORATUVAR 2 · AHC RAPID DRILLING 4014 SÜRÜMÜ

2 IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

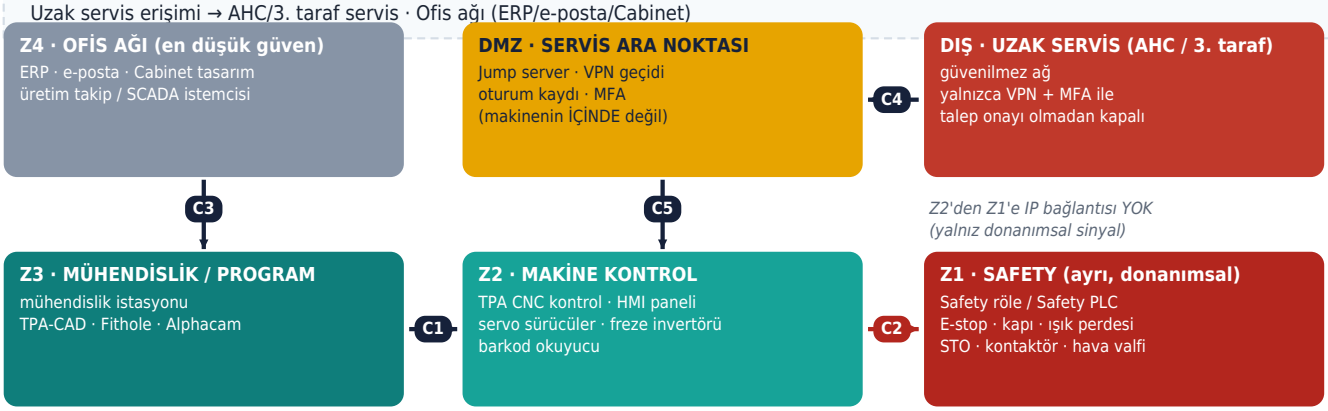
Makine: AHC Makine RAPID DRILLING 4014 · CNC Çoklu Delik Delme / Freze İşleme Merkezi (AİMSAD)

Ad Soyad **Grup** **Tarih:** 24.10.2026

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi (4014 karşılığı): PLC → TPA CNC kontrol · HMI → operatör paneli · Robot kontrolörü → servo sürücüler + freze invertörü · **Safety PLC** → emniyet rölesi/Safety PLC · SCADA istemcisi → üretim takip/barkod istemcisi · Mühendislik istasyonu → TPA-CAD/Fithole/Alphacam PC'si · Uzak servis erişimi → AHC/3. taraf servis · Ofis ağı (ERP/e-posta/Cabinet)



1 **Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.**

Z1 Safety: safety röle/PLC, E-stop, kapı/ışık perdesi, STO hatları. **Z2 Makine Kontrol:** TPA CNC, HMI, servo sürücüler, freze invertörü, barkod okuyucu. **Z3 Mühendislik/Program:** TPA-CAD/Fithole/Alphacam PC'si, üretim takip istemcisi. **DMZ Servis:** jump server + VPN geçidi. **Z4 Ofis:** ERP, e-posta, Cabinet tasarım. **Dış:** uzak servis (güvenilmez).

2 **Safety PLC'yi hangi bölgeye koydunuz — neden?**

Kendi bölgesine (Z1), Z2'den ayrı. Saldırı etkisi en yüksek varlık (insan güvenliği) olduğu için en az bağlantı alır: Z2 ile yalnızca **donanımsal sinyal** ("safety OK", reset isteği), IP bağlantısı yok. Diğer bölgelerden biri ele geçse bile safety yolu etkilenmemeli.

3 · Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

Conduit	Geçiş	Kontrol
C1	Z3 → Z2 (program aktarımı)	Yalnız tek yönlü, yetkili kullanıcıyla dosya aktarımı; dosya türü/imza/zararlı yazılım taraması; USB varsayılan kapalı; hedef IP/port beyaz liste.
C2	Z2 ↔ Z1	Sadece donanımsal I/O (safety durumu, reset). Ağ/IP yok. Safety ayarı yalnız yerinde, anahtarlı/şifreli, değişiklik kaydıyla.
C3	Z4 → Z3	Güvenlik duvarı; yalnız iş emri/tasarım dosyası akışı; e-posta eki doğrudan Z3'e değil, taramadan sonra.
C4	Dış → DMZ	VPN + MFA, kişisel hesap, onaylı servis talebi, süreli açılış, oturum kaydı.
C5	DMZ → Z2	Yalnız jump server üzerinden, tek hizmet/port, en az yetki, tam oturum kaydı; Z2'den internete çıkış yok.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump server.** Doğrudan bağlantı TPA PC'yi dışarıya açar; tek, denetlenen kapı saldırı yüzeyini daraltır.
Tünel?	Açık / VPN	**VPN.** Şifreli ve kimliği doğrulanmış tünel; açık port/uzak masaüstü doğrudan internete maruz kalmaz.
Kimlik?	Parola / MFA	**MFA.** Çalınmış parola tek başına yetmez (Lab 6 senaryosu servis hesabı ihlalidir).
Hesap?	Paylaşılan / Kişisel	**Kişisel.** Kim, ne zaman, ne yaptı izlenir; ayrılan kişinin erişimi kapatılabilir.
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı.** Olay sonrası kanıt ve CRA bildirimi için gerekli.
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı.** Servis talebi onaylanınca süreli açılır; makine çalışırken gereksiz erişim yok.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.